

IDOR Vulnerability Report

Severity	High
Vulnerability Type	IDOR (Broken Access Control)
Endpoint	https://[REDACTED]806082

Description

The application is vulnerable to an Insecure Direct Object Reference (IDOR) in the order tracking endpoint. An attacker can manipulate the order ID in the URL to access other users' order details without proper authorization checks.

Steps to Reproduce

- 1 Login as a normal user.
- 2 Capture the request using Burp Suite.
- 3 Modify the order ID in the request.
- 4 Send the modified request.
- 5 Observe unauthorized access to another user's order.

Impact

- 1 Exposure of sensitive order details
- 2 Disclosure of customer personal data
- 3 Violation of user privacy
- 4 Potential business loss and trust issues
- 5 Possibility of account takeover in chained attacks

Root Cause

- 1 Missing authorization validation
- 2 No ownership check on order resource

Recommended Fix

- 1 Implement strict access control checks
- 2 Ensure order belongs to logged-in user
- 3 Use UUID instead of sequential IDs
- 4 Apply RBAC and server-side validation

Conclusion

This vulnerability poses a significant risk due to improper access control. Immediate remediation is recommended to prevent unauthorized data exposure and potential exploitation.